VULNERABILITY ASSESSMENT REPORT

19 June 2026

Website: OWASP Juice Shop Demo

Read Only Vulnerability Assessment

Prepared by:

Entisaar Elfadl

Table of Contents

Executive Summary 3
Purpose of Assessment 3
Scope 3
Methodology 3
Tools Used 3
Assessment Findings 5
Positive Security Controls 6
Risk Summary 7
Recommendations 7
Conclusion 7
Appendix 8

Executive Summary

Purpose of Assessment

The purpose of this assessment was to evaluate the security posture of the OWASP Juice Shop demo application using passive, non-intrusive techniques. The assessment focused on identifying publicly visible security weaknesses without attempting to exploit any vulnerabilities.

The assessment was conducted using network scanning, HTTP security header analysis, browser developer tools, and HTTPS configuration review.

Overall, the website demonstrated several positive security controls, including the use of HTTPS and certain browser security headers. However, several missing security headers and exposed network services were identified that could increase the application's attack surface if left unaddressed.

Scope

Target Website

https://demo.owasp-juice.shop/#/

Assessment Type

Read Only Vulnerability Assessment

Included Activities:

- Network port scanning
- HTTP security header analysis
- Browser response header inspection
- SSL/TLS configuration review

Excluded Activities:

- Exploitation
- Brute force attacks
- Authentication bypass
- Denial of Service attacks
- Any intrusive testing

Methodology

This assessment followed a structured process that was inspired by the guidelines

1. Selected a publicly accessible web application suitable for ethical security assessment.
2. Performed a network scan using Nmap to identify publicly exposed services.
3. Inspected HTTP response headers using browser developer tools.
4. Analysed implemented and missing security headers using SecurityHeaders.com.
5. Documented findings, classified risks, and developed remediation recommendations.

Tools Used

Tool	Purpose
Nmap	Network port scanning

SecurityHeaders.com	HTTP security header analysis
Browser Developer Tools	Response header inspection
Microsoft Word	Report design

Assessment Findings

1. Exposed Network Services

Risk Level:
Medium

Description:
Scan identified several publicly accessible services running on the target server.
Open Ports Detected:

- FTP (21)
- HTTP (80)
- HTTPS (443)
- HTTP Proxy (8080)
- Port(1723 was filtered)

Impact:
Every publicly accessible service increases the organization's attack surface. While not all exposed services represent vulnerabilities, unnecessary services may provide attackers with additional opportunities for reconnaissance or exploitation if they become misconfigured or outdated.

Evidence:

```
C:\Users\entis>nmap demo.owasp-juice.shop
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 13:38 +0200
Nmap scan report for demo.owasp-juice.shop (81.169.145.156)
Host is up (0.20s latency).
Other addresses for demo.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 995 closed tcp ports (reset)
PORT     STATE    SERVICE
21/tcp   open     ftp
80/tcp   open     http
443/tcp  open     https
1723/tcp filtered pptp
8080/tcp open     http-proxy

Nmap done: 1 IP address (1 host up) scanned in 9.70 seconds
```

Recommendation:

- Disable services that are not required.
- Restrict access to administrative services.
- Perform regular reviews of exposed network services.

2. Missing Content Security Policy Header

Risk Level:
Medium

Description:
Scan assessment identified that the website does not implement a Content Security Policy (CSP).
A CSP restricts which sources of content a browser is allowed to load, helping to mitigate attacks such as Cross Site Scripting (XSS).

Impact:
Without a Content Security Policy, attackers may have an easier opportunity to execute malicious scripts if an injection vulnerability exists elsewhere in the application..

Evidence:

▾ Response headers

Accept-Ranges	bytes
Access-Control-Allow-Origin	*
Cache-Control	public, max-age=0
Date	Fri, 19 Jun 2026 11:43:39 GMT
Etag	W/"26af-19edf997b19"
Feature-Policy	payment 'self'
Last-Modified	Fri, 19 Jun 2026 11:17:18 GMT
Nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction":0.1}
Report-To	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=xqvbu0LuFqbfxnuKqRndV3AjOb7EfWBEvDB%2BHxSAk%2FQ%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1781869419"}],"max_age":3600}
Reporting-Endpoints	heroku-nel="https://nel.heroku.com/reports?s=xqvbu0LuFqbfxnuKqRndV3AjOb7EfWBEvDB%2BHxSAk%2FQ%3D&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&ts=1781869419"
Server	Heroku
Via	1.1 heroku-router
X-Content-Type-Options	nosniff
X-Frame-Options	SAMEORIGIN
X-Recruiting	/#/jobs

Recommendation:
Implement a Content Security Policy that explicitly defines trusted sources for scripts, stylesheets, images, and other resources.

3. Missing Referrer Policy Header

Risk Level:
Low

Description:
The Referrer Policy header was missing. This header controls how much information browsers send when users follow links to other websites.

Impact:
Sensitive information contained in URLs could unintentionally be shared with third party websites.

Evidence:

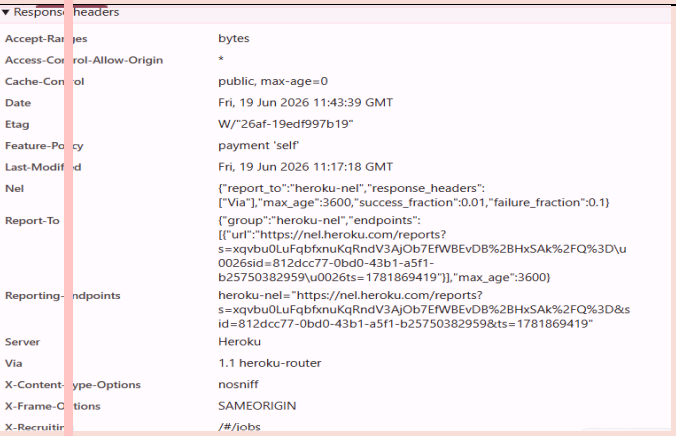
4. Missing Permissions Policy Header

Risk Level:
Low

Description:
The Referrer Policy header was missing. This header controls access to browser features like such as camera, microphone, and geolocation.

Impact:
Missing restrictions may allow unnecessary browser capabilities to remain available if future application functionality is introduced.

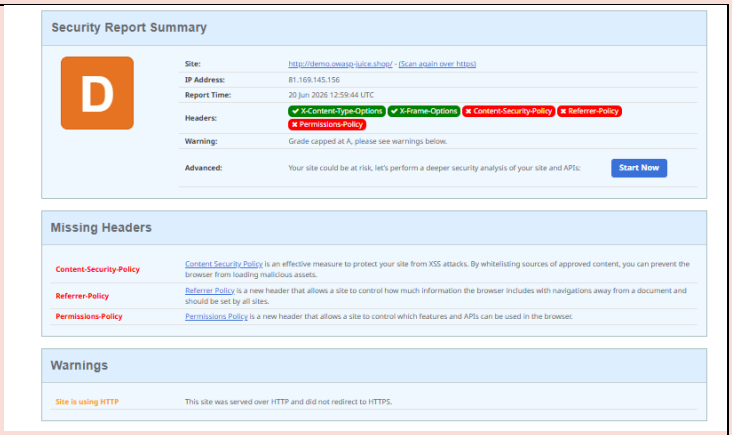
Evidence:



▾ Response headers

Accept-Ranges	bytes
Access-Control-Allow-Origin	*
Cache-Control	public, max-age=0
Date	Fri, 19 Jun 2026 11:43:39 GMT
Etag	W/"26af-19edf997b19"
Feature-Policy	payment 'self'
Last-Modified	Fri, 19 Jun 2026 11:17:18 GMT
Nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction":0.1}
Report-To	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=xqvbu0LuFqbfxnuKqRndV3AjOb7EfWBEvDB%2BHxSAk%2FQ%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1781869419"}],"max_age":3600}
Reporting-Endpoints	heroku-nel="https://nel.heroku.com/reports?s=xqvbu0LuFqbfxnuKqRndV3AjOb7EfWBEvDB%2BHxSAk%2FQ%3D&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&ts=1781869419"
Server	Heroku
Via	1.1 heroku-router
X-Content-Type-Options	nosniff
X-Frame-Options	SAMEORIGIN
X-Recruiting	/#/jobs

Recommendation:
Configure an appropriate Referrer Policy, such as *strict-origin-when-cross-origin.*



Recommendation:
Implement a Permissions Policy that disables browser features not required by the application.

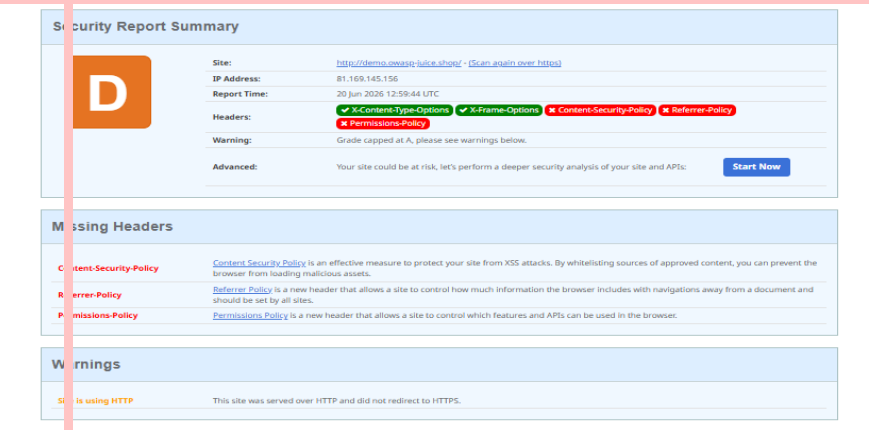
5. Website Accessible Over HTTP

Risk Level:
Medium

Description:
The assessment indicated that the website could be accessed over HTTP. Although HTTPS is available, HTTP connections increase the possibility of unencrypted communication if users access the insecure version.

Impact:
Users may unknowingly access the unencrypted version of the site, increasing the risk of interception during transmission.

Evidence:



Recommendation:
Redirect all HTTP traffic automatically to HTTPS and enable HTTP Strict Transport Security (HSTS).

Positive Security Controls

Not all the findings were negative as the scanned results also showed several good security practices:

- The security headers that were implemented were X Content Type Options and X Frame Options.
- These headers help protect users against MIME type sniffing and clickjacking attacks.

- HTTPS was successfully configured, allowing encrypted communication between clients and the web application.

Risk Summary

Finding	Risk
Exposed Network Services	Medium
Missing Content Security Policy	Medium
Website Accessible Over HTTP	Medium
Missing Referrer Policy	Low
Missing Permissions Policy	Low

Recommendations

To improve the application's security posture, I would recommend:

- Remove or restrict unnecessary publicly exposed services.
- Implement a Content Security Policy.
- Configure a Referrer Policy.
- Configure a Permissions Policy.
- Redirect all HTTP requests to HTTPS.
- Continue performing regular vulnerability assessments.
- Keep server software updated.
- Review security configurations periodically.

Conclusion

A passive vulnerability assessment was conducted on the OWASP Juice Shop demo application using industry standard tools and ethical assessment techniques.

The assessment identified several medium and low risk security observations. The most significant findings were the presence of multiple exposed services, missing browser security headers, and the availability of the application over HTTP. As the target website is an intentionally vulnerable training environment, these findings are expected and serve to demonstrate common web application security weaknesses.

Although the application implements certain security controls, including HTTPS support and selected browser security headers, additional hardening measures would further improve its overall security posture.

Implementing the recommended controls would reduce the application's attack surface and strengthen protection against common web-based attacks.

Appendix

Security Report Summary

D

Site:	http://demo.owasp-juice.shop/ - (Scan again over https)
IP Address:	81.169.145.156
Report Time:	20 Jun 2026 12:59:44 UTC
Headers:	✔ X-Content-Type-Options ✔ X-Frame-Options ✖ Content-Security-Policy ✖ Referrer-Policy ✖ Permissions-Policy
Warning:	Grade capped at A, please see warnings below.
Advanced:	Your site could be at risk, let's perform a deeper security analysis of your site and APIs: Start Now

Missing Headers

Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Warnings

Site is using HTTP	This site was served over HTTP and did not redirect to HTTPS.

Raw Headers

HTTP/1.1	200 OK
Date	Sat, 20 Jun 2026 12:59:44 GMT
Server	Heroku
Accept-Ranges	bytes
Access-Control-Allow-Origin	*
Cache-Control	public, max-age=0
Content-Encoding	gzip
Content-Type	text/html; charset=UTF-8
Etag	W/"26af-19ee4b926ab"
Feature-Policy	payment 'self'
Last-Modified	Sat, 20 Jun 2026 11:09:59 GMT
Nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction":0.1}
Report-To	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=Ke%2BCxrHtp4EeN5JHjvj2CxLzXytqOHxfcl7a1Urt2KA%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1781960384"}],"max_age":3600}
Reporting-Endpoints	heroku-nel="https://nel.heroku.com/reports?s=Ke%2BCxrHtp4EeN5JHjvj2CxLzXytqOHxfcl7a1Urt2KA%3D&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&ts=1781960384"
Vary	Accept-Encoding
Via	1.1 heroku-router
X-Content-Type-Options	nosniff
X-Frame-Options	SAMEORIGIN
X-Recruiting	/#/jobs

Appendix A: Header Scanner scr1

Transfer-Encoding	chunked

Upcoming Headers

Cross-Origin-Embedder-Policy	Cross-Origin Embedder Policy allows a site to prevent assets being loaded that do not grant permission to load them via CORS or CORP.
Cross-Origin-Opener-Policy	Cross-Origin Opener Policy allows a site to opt-in to Cross-Origin Isolation in the browser.
Cross-Origin-Resource-Policy	Cross-Origin Resource Policy allows a resource owner to specify who can load the resource.

Additional Information

Server	Server value has been changed. Typically you will see values like "Microsoft-IIS/8.0" or "nginx 1.7.2".
Access-Control-Allow-Origin	This is a very lax CORS policy. Such a policy should only be used on a public CDN.
Feature-Policy	Feature Policy has been renamed to Permissions Policy, see the details here.
Nel	Network Error Logging is a new header that instructs the browser to send reports during various network or application errors. You can sign up for a free account on Report URI to collect these reports.
Report-To	Report-To enables the Reporting API. This allows a website to collect reports from the browser about various errors that may occur. You can sign up for a free account on Report URI to collect these reports.
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking.

Appendix B: Header Scanner scr2

```
C:\Users\entis>nmap demo.owasp-juice.shop
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 13:38 +0200
Nmap scan report for demo.owasp-juice.shop (81.169.145.156)
Host is up (0.20s latency).
Other addresses for demo.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 995 closed tcp ports (reset)
PORT     STATE    SERVICE
21/tcp   open     ftp
80/tcp   open     http
443/tcp  open     https
1723/tcp filtered pptp
8080/tcp open     http-proxy

Nmap done: 1 IP address (1 host up) scanned in 9.70 seconds
```

Appendix C: Nmap Network Scan

▼ Response headers

Accept-Ranges	bytes
Access-Control-Allow-Origin	*
Cache-Control	public, max-age=0
Date	Fri, 19 Jun 2026 11:43:39 GMT
Etag	W/"26af-19edf997b19"
Feature-Policy	payment 'self'
Last-Modified	Fri, 19 Jun 2026 11:17:18 GMT
Nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction":0.1}
Report-To	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=xqvbu0LuFqbfxnuKqRndV3AjOb7EfWBEvDB%2BHxSAk%2FQ%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1781869419"}],"max_age":3600}
Reporting-Endpoints	heroku-nel="https://nel.heroku.com/reports?s=xqvbu0LuFqbfxnuKqRndV3AjOb7EfWBEvDB%2BHxSAk%2FQ%3D&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&ts=1781869419"
Server	Heroku
Via	1.1 heroku-router
X-Content-Type-Options	nosniff
X-Frame-Options	SAMEORIGIN
X-Recruiting	/#/jobs

Appendix D: Security Headers Inspection